IITGN Feedback · system architecture and trust boundaries

Two HTTPS origins. The identity side knows who you are; the anonymous side sees answers. They share only the poll ID. Source: SPEC.md §6, §8, §12, §14.

Organiser's browser
portal app: drafts, eligibility list, open / close, results

Participant's browser · desktop Chrome or Firefox

Claim popup · portal origin
shows your signed-in account + poll, forwards only the blinded request

postMessage (exact origins, nonce)
blinded request ⇄ blind signature

Response tab · respond origin
makes the secret, blinds it, unblinds and verifies the stamp, keeps the credential in IndexedDB until it is used

Secrets never go in URLs, cookies, server storage or the clipboard. After a confirmed submission the credential and answers are erased.

HTTPS · session + CSRF

POST claim: blinded request (session + CSRF)

POST response: {credential, answers}

Identity side · portal.feedback.example

Portal API · Node 24, Fastify
Google sign-in, sessions + CSRF, organiser routes.
Issuer: checks eligibility, records one claim per account, then asks the signer.

blinded request + poll key → blind signature

per-poll private key

Native RSA signer · workerd
loopback only, no database access.
Blind-signs; never sees the message.

Encrypted key volume
one RSA-3072 key per poll, destroyed within 24 h of closing

Anonymous side · respond.feedback.example

Response API · Node 24, Fastify
public poll + key, verifies the stamp, stores each credential's answers once.
No cookies, no sign-in.

Ingress strips cookies, Authorization, IP-forwarding, User-Agent and trace headers. No access logs. Rate limits are keyed by route or poll, never by person.

OIDC code flow (server-side, PKCE)

eligibility, sessions, one claim per account

drafts, open / close, public keys

public poll + key

redeem once: nullifier + answers

Google OIDC
iitgn.ac.in Workspace accounts
(signed hd claim checked)

PostgreSQL 17 · separate schemas + roles

identity.*
users (issuer, subject) · sessions
eligibility: exact emails per poll
claims: (poll, user, entry), nothing else

polls · signing_keys
frozen questions, deadline, policy
public key only; private keys
stay on the key volume

anonymous.*
responses: (poll, nullifier, answers)
no account, IP, user-agent or time
result snapshots: after closing, ≥ 5 responses,
read only through an owner-gated function

Legend
- Identity side: knows who you are
- Anonymous side: sees answers
- Your browser
- Shared, trusted infrastructure
- External or isolated service

The only value both sides share is the poll ID. Claim rows hold no credential material and response rows hold no account, IP address, user-agent or timestamp, so there is no respondent-level join (SPEC.md §1, §12).